



Information Security Overview

V2.3 – last updated 27 Mar 2023

Contents

1. Internal Application Controls	Page 3
2. Software Build and Deployment Controls	Page 4
3. Encryption, APIs and Data Storage	Page 4
4. Infrastructure Management	Page 5
5. Data Centre and Services	Page 5
6. Other 3 rd Party Services	Page 5

Contact Details

We welcome any questions enquiries about this document or our information security in general. Please contact:

Hamish Rickerby

Chief Technology Officer

BeeCastle

+64 22 503 7281

hamish@beecastle.com

1. Internal Application Controls

BeeCastle is designed to be a collaborative, information sharing system within the context of an Account. Data within an Account is typically readable and writable to all Users within that Account.

BeeCastle does support role-based access controls (RBAC), however the current support for roles within the application is limited. There are 4 roles available for usage within the platforms: admin, manager, billing, and user.

By default, the user that created the account (signed up) is allocated all roles. Any invited users join with the user role. Currently user/role assignment is performed by request to the BeeCastle CSM team.

The current restrictions within the platform based on role are below:

- Access to exporting data from reporting tables is restricted to the admin role.
- Access to the team reporting page is restricted to the manager role.
- Access to the payment/billing page in settings is restricted to the billing role.
- Access to interaction titles and notes is enabled for all roles by default, but can be restricted to admin only

We plan on both extending the usage of roles within the platform, and enabling end-user admins to manage user roles.

Users are added to the platform by invite from an existing user only. A new user cannot join an account without being invited.

Users can be removed from the platform by navigating to the user list and selecting "Archive Account".

Users will use either an email/password combination or their Microsoft 365 credentials to log in. A user will have a single set of credentials, so cannot use both a password and Microsoft credentials to log in. Microsoft credentials have precedence, so if a user logs in with Microsoft and previously used a password, the password will be removed from their account and they can only use Microsoft from that point on. This allows for centralised user management via an organisations AAD instance, including enforcement of policies such as 2FA.

Unless explicitly invited, BeeCastle employees cannot access the users/account application instance.

2. Software Build and Deployment Controls

All software build and deployment processes are automated within BeeCastle. The ability to commit code is restricted to authorised users, and management of authorised users is the responsibility of the CEO and CTO.

The build and deployment pipeline is triggered automatically upon branch-specific commits, and tests/validation are run before deployment. Any failing tests or linting will cause the build to fail, and deployment will not run.

Deployment to AWS is based on AWS's IAM controls. The build server user has needs-based access, and only the specific functions available. These controls are enforced by AWS.

Deployment requires 0 downtime. Extra application instances are spun up for deployment, and when they are ready production load is switched to them and away from application instances that still need to be updated. There is rolling deployment from this point onwards. This process is entirely automated.

3. Encryption, APIs and Data Storage

All connections to and from the BeeCastle infrastructure are encrypted with either HTTPS or TLS. All application access to BeeCastle is via HTTPS, with modern encryption protocols used (AES-128).

Submission of any interaction data to BeeCastle is opt-in, controlled either by the user or the organisations IT administrators. Email ingestion is supported at an organisation level, with the customers IT administrators being in control of emails that get delivered to BeeCastle for ingestion and rating.

For email submission via journalling or auditing, BeeCastle enforces usage of TLS. Email data is encrypted on receipt via KMS with a self-managed key, and body content is stripped before submission to the BeeCastle backend. BeeCastle backend never sees the content of any email. Email data is also deleted on submission to the backend.

Email and interaction submission via Microsoft 365 is driven by Microsoft. BeeCastle is notified when new or updated data is available, and BeeCastle queries the data that it needs to rate the interaction.

For connectivity with cloud or self hosted PSA's (Autotask, Connectwise, HaloPSA), BeeCastle enforces HTTPS. We retrieve data related to companies, contacts, and company teams for a basic integration. For a whitespace integration, we also require the ability to read invoices, products, and agreements. We push (on users request) Opportunities back into the PSAs. The approach for ongoing synchronisation with PSAs is similar to that with Microsoft – we utilise webhooks to configure the PSAs to notify us of changes in the entities we are interested in. BeeCastle will then securely connect back to the PSA and query the data it requires. For synchronisation of data entities that are not supported via webhooks, BeeCastle will perform periodic batch synchronisation to keep the data timely. The schedule for this synchronisation depends on the PSA and data entity, but ranges from daily to weekly.

General connectivity into the BeeCastle infrastructure is all secured through an AWS load balancer and security group, both configured to only support HTTPS (port 443) and a listener on 443 only. Notifications from Microsoft are similarly secured via HTTPS, and this runs through an API Gateway service. Notifications from Microsoft also rely on shared secrets between the two parties, providing a level of certainty around the source of the notifications. There are no other inbound external connections supported into the BeeCastle infrastructure.

All inbound requests to the BeeCastle application and APIs are monitored, tracked, and logged, with date/time, IP address, and the request made.

Data stored within BeeCastle is encrypted-at-rest on both file storage and database files. This ensures that in the event of a physical attack on a data centre, theft of a disk would not result in data being readable.

Database backups are taken every 6 hours, with a 2 day retention cycle. We also take daily backups with a 7 day retention, weekly with a 4 week retention, and monthly with a 13 month retention. We also periodically test restoration of the backups.

4. Infrastructure management

The majority of infrastructure to support BeeCastle has automated deployment and maintenance. A small number of the subsystems in place do require manual creation, so in the case of a catastrophic failure, they would need manual intervention.

To support horizontal scalability, fault tolerance and recovery, the infrastructure is monitored and managed by AWS. In the case of system slowdown or elevated error rates, extra compute units are created to manage increased load. These are also scaled down automatically when system load is low. Similar to software deployment, permissions for inter-service connectivity are managed by AWS IAM. Where applicable, AWS resource-based policies are used for this.

BeeCastle has enabled auditing on changes within AWS infrastructure, so any change is logged and can be reviewed. BeeCastle also uses AWS CloudWatch for centralised log management, with usage of the resource policies mentioned above for permitting access to these logging services from systems.

5. Data Centre and Services

BeeCastle uses cloud services from Amazon's AWS, Microsoft's Azure, and Google's GCP service. The majority of services are on AWS, with utilisation of some very specific cloud services to support the BeeCastle applications being provided by Azure and GCP. Because cloud services are utilised, our cloud service providers are responsible for physical server security, network infrastructure security, OS updates, and patching. Their documentation on security and the responsibility of different parties is linked to below.

<https://aws.amazon.com/compliance/shared-responsibility-model/>

<https://cloud.google.com/security/overview/whitepaper>

We also have a significant integration footprint with ConnectWise in terms of data synchronisation. Their security and privacy documentation is available below.

<https://www.connectwise.com/company/trust>

6. Other 3rd Party Services

BeeCastle utilises several other cloud services to support operations on and development of its platform. These are listed below

- Amplitude - mobile application analytics
- Google Analytics - web application analytics
- Apple App Store - mobile analytics, mobile application distribution
- Intercom - analytics, help, and customer support
- Stripe - payment processing
- Microsoft Teams and Outlook - infrastructure for supporting presentation of BeeCastle interfaces and services
- SendGrid - email delivery and tracking
- OneSignal - Push Notification delivery
- Microsoft AAD - authentication services
- Microsoft Graph - contact, call, calendar, and email data ingestion
- MongoDB - SaaS based database management, deployed on AWS
- Autotask – synchronisation of company, contact, and sales data
- ConnectWise Manage – synchronisation of company, contact, and sales data
- HaloPSA– synchronisation of company, contact, and sales data

Each of these providers will have security information available on their websites